

Certified clinical-impact bounds for security-control selection: a distribution-free method on an ATT&CK-driven hospital model

2026-09-20 (working note, version 0.1.0)

Abstract

Security-control decisions in hospitals are usually justified by abstract scores (CVSS, coverage counts, reachability) that say nothing about patients. We pose and solve a different problem: given a set of candidate defensive controls, certify — distribution-free, and robustly over acknowledged parameter uncertainty — that the probability of a sustained *clinical-service* outage stays below a chosen level. The model is a better synthetic hospital: its attack surface is the real MITRE ATT&CK Enterprise kill chain (v17.1) with controls drawn from ATT&CK’s own mitigations, and its damage is patient-facing outage of the 4 core clinical services through an explicit service-dependency structure. Because every quantity is coordinatewise monotone in the model parameters, adequacy is certified by evaluating the interval corners — the necessary/possible argument, lifted from efficiency to clinical outcome. The undefended union-bound clinical outage is 44.9%, matching the independently reported 44% care-disruption rate. Identity controls dominate: a four-control identity bundle certifies clinical outage $\leq 5\%$, while backup, segmentation, or patching alone each leave the outage near the undefended level. The contribution is the method and problem formulation; effectiveness and degradation are evidence-anchored intervals, not measurements of any hospital.

1 Problem and model

Let a control portfolio be a set of ATT&CK mitigations. The adversary traverses the real ATT&CK kill chain; a portfolio lowers technique success through ATT&CK’s **mitigates** edges. *Impact reachability* R is the probability of completing the chain to the clinical-impact tactic (T1486 encryption, T1490 inhibit recovery, T1489 service stop, T1485 destruction), computed as a product of usage-weighted stage successes. A clinical service s then suffers a sustained outage with probability $R \cdot d_s$, where d_s is a service-specific degradation probability. Writing $O_s = R d_s$, we bound clinical impact two ways: per service, and by the union bound $\sum_s O_s \geq \Pr(\geq 1 \text{ service out})$.

Every parameter is an interval anchored to a published figure (base progression from Mandiant/Sophos dwell data; mitigation effectiveness from the Microsoft MFA study and a wide prior elsewhere; degradation $d_s \in [0.17, 0.44]$ from Neprash 2022 and McGlave 2026). O_s and the union bound are increasing in base and degradation and decreasing in effectiveness.

2 Certificate

Monotonicity places the extremes of every bounded quantity at the corners of the interval uncertainty set. A portfolio is *guaranteed* clinically adequate at level ε when, at the adverse corner (base high, effectiveness low, degradation high), every per-service outage *and* the union bound are $\leq \varepsilon$; it is only *possible* when this holds merely at the favourable corner. The guarantee is distribution-free:

Table 1: Certified cost-versus-outage frontier (first eight greedy additions): control added and worst-case union clinical outage after it, percent.

Size	Mitigation	Name	Worst union outage (%)
1	M1032	Multi-factor Authenticatio	13.6
2	M1018	User Account Management	7.7
3	M1031	Network Intrusion Preventi	4.7
4	M1026	Privileged Account Managem	3.0
5	M1047	Audit	2.0
6	M1040	Behavior Prevention on End	1.4
7	M1038	Execution Prevention	1.0
8	M1017	User Training	0.7

Table 2: Named control bundles: worst-case union clinical outage and certificates.

Bundle	Size	Worst union (%)	Guar. $\leq 10\%$	Guar. $\leq 5\%$
identity	4	4.2	yes	yes
backup	1	37.9	no	no
segmentation	1	35.9	no	no
patching	1	37.4	no	no
detection	2	27.9	no	no
hospital core	5	5.3	yes	no

it holds for every parameter value in the set, with no distributional assumption. Where incident counts exist, finite-sample betting bounds supply the intervals.

3 Results

Undefended clinical outage is 44.9% (union bound), a figure that coincides with the independently observed 44% care-disruption rate — a coherence check on the anchoring, not a fitted result. Along the certified cost-versus-outage frontier, 2 controls guarantee union outage $\leq 10\%$, 3 guarantee $\leq 5\%$, and 7 guarantee $\leq 1\%$ (Table 1). Of the named bundles, only the identity bundle is guaranteed at 5% (union outage 4.2%); the hospital-core bundle reaches 5.3%, and single-family controls barely move the outcome — data backup alone leaves 37.9% (Table 2). The policy reading is blunt and, to our knowledge, not something prior control-scoring methods can state with a guarantee: for bounding *patient-facing* outage, identity controls dominate and no single other family suffices.

4 Sensitivity to assumed uncertainty

To guarantee union outage $\leq 5\%$, a narrow effectiveness prior needs 3 controls and a wide prior needs 14: the distribution-free guarantee demands more coverage precisely when less is known, which is the honest behaviour a hospital decision-maker should want.

5 Contribution and limitations

The novelty is the formulation and method: a distribution-free certificate on *patient-facing clinical outage* for control portfolios, composing a real ATT&CK attack graph with a hospital service-dependency model, rather than scoring abstract reachability. Limitations, stated plainly: ATT&CK **mitigates** edges are qualitative, not effect sizes; the impact-technique-to-service mapping, the degradation probabilities, and the kill-chain progression are modelling choices anchored to published ranges, not measured on a hospital; the model is synthetic and unvalidated against incidents; and the union bound is deliberately conservative. This is decision-support with an explicit guarantee under stated uncertainty, not an empirical estimate of any hospital’s risk.

Reproducibility. MITRE ATT&CK v17.1 is used unmodified (Terms of Use), pinned and hashed; all outputs carry a provenance manifest and every number here is generated from the committed tables.